

UAE data-protection notes for the Lumi Skin assistant

System	The Lumi Skin customer-service AI assistant (shop-support-agent, project P1)
Date	8 October 2026. The facts were checked against the sources in sources.md on this date.
Status	General information, for a portfolio project about a fictional company

General information only. This is not legal advice. The UAE has several data-protection regimes, and the rules are still being filled in. Ask a UAE-qualified lawyer before you collect real customer data.

1. Which law applies?

Where the business runs	Main law	Notes
Onshore UAE (for example, a Dubai mainland company like the fictional Lumi Skin)	Federal Decree-Law No. 45 of 2021 on the Protection of Personal Data (the "PDPL") [UAE-1]	Issued on 20 September 2021; in force since 2 January 2022. The Arabic text prevails over the English one.
Dubai International Financial Centre (DIFC)	DIFC Data Protection Law No. 5 of 2020 and its Data Protection Regulations, including Regulation 10 on autonomous and semi-autonomous systems [DIFC-1]	The PDPL does not apply to free zones that have their own data-protection law (PDPL Art. 2).
Abu Dhabi Global Market (ADGM)	ADGM Data Protection Regulations 2021	Not covered in these notes.

The PDPL also does **not** apply to government data, to health data or banking and credit data that have their own laws, or to data a person processes for personal purposes (Art. 2) [UAE-1].

Status check on 8 October 2026. Two things are still unsettled:

- **The Executive Regulations have not been issued.** Article 28 asks for them; Al Tamimi (1 September 2026) and Ashurst Perkins Coie (July 2026) both report that they are still pending [UAE-3, UAE-4]. Under Article 29, companies get a period of up to six months *after* the Regulations are issued to bring themselves into line. Some details are therefore still unknown, for example how cross-border transfers will be approved.
- **The regulator is changing.** On 14 June 2026 the UAE announced a federal Artificial Intelligence and Data Authority. It absorbs the UAE Data Office, which is the regulator named in the PDPL [UAE-3].

The practical approach is to **build to the text of the law now**, so that only small changes are needed when the Regulations arrive.

2. What personal data the assistant touches (data inventory)

This inventory is based on P1's synthetic data files and on the logs P1 writes. All the data in this project is synthetic. A real launch would hold the same types of data about real people.

Data	Example field(s)	Where it lives	Why it is needed	Possible lawful basis (PDPL Art. 4)	Notes
Identity and contact	name, email, phone	customers.csv (the CRM)	To verify the customer and reply to them	Performing the sales contract	The agent must check that the order ID and the email

					match before it shows any order detail
Address	address, city, country	customers.csv; the CRM address overrides	Delivery and address changes	Performing the contract	Every change is approved by a person
Orders and payments	order_id, total_aed, payment_method, status	orders.csv, order_items.csv	Order support and refunds	Performing the contract	The assistant cannot move money. It can only request a refund.
Delivery tracking	tracking_id and its events	tracking_events.csv, read through the courier API	Answering "where is my order?"	Performing the contract	—
Language preference	language (ar/en/fr)	customers.csv	Replying in the right language	Performing the contract	—
Chat content	Free text typed by the customer	The in-memory conversation state; handover tickets (up to 500 characters of the last message); sent to the model provider on every turn. The model-call traces do not store it.	Answering the question; quality review	Contract (for answering). Consent or another basis is needed for "to improve the service" ; ask counsel	Customers may type health information , such as skin conditions, pregnancy or prescriptions. That is sensitive data (see section 3.4).
Approval decisions	Who approved what, and when	approval_log.jsonl	Accountability and audit	Legal obligation and accountability	Keep it for the retention period in the runbook
Marketing preference	Opt-in to offers	Not built in P1	Sending offers	Consent (the shop policy says opt-in)	The customer can object to direct marketing at any time (Art. 17)

3. How the PDPL affects collecting customer data in the chat

3.1 A lawful basis for every use (Arts. 4 and 6)

- Under the PDPL, processing needs **consent**, unless one of the Article 4 exceptions applies. One exception is processing needed to perform a contract with the data subject [UAE-1].
- Order support fits the contract exception.
- Marketing and "improving the service" from chat logs probably need **consent**, or a basis that counsel confirms.
- Consent must be "clear, simple, unambiguous and easily accessible", it must be provable, and it must be as easy to withdraw as to give (Art. 6) [UAE-1].

What the chat should do. Show a short privacy notice with the AI disclosure. A draft is in section 6. Do not use chat logs for model training.

3.2 Collect only what is needed; record what you hold (Arts. 5 and 7)

The controller must keep a **record of processing** (Art. 7) [UAE-1]. The inventory above is a first version of that record.

Data minimisation in P1:

- The assistant asks only for the **order ID and email** to verify a customer. It never asks for card numbers or passwords.
- Tools return only the fields needed for the task.

Checked in P1's code (8 October 2026):

- the model-call traces (`llm.Tracer`) store metadata only: model, tokens, cost, latency and outcome, with no message text;
- the order facts sent to the model (`order_view()`) contain no name, email or phone.

Still open:

- what the customer *types* (often their email) goes to the model as it is;
- handover tickets keep up to 500 characters of the last message.

Both are tracked as R13 and R14.

3.3 Automated decisions (Art. 18)

A data subject can object to decisions that come from automated processing, including profiling, when those decisions have legal consequences or seriously affect them [UAE-1].

How P1 handles this. Lumi does **not** make decisions about money or personal data on its own. Every refund and every address change waits for a human decision in the approvals queue. Refunds above AED 200 need a supervisor. This design keeps the significant decisions human. Section 4 of the [human-oversight runbook](#) describes it.

3.4 Sensitive data: health information typed into the chat

- Skincare questions can lead customers to share health details, such as eczema, pregnancy or a prescription treatment.
- The PDPL treats health data as **sensitive personal data**, which needs more care.

Controls.

- The shop policy and the assistant's product advice say that the guidance is general, not medical. People with a skin condition, a pregnancy or a prescription treatment are referred to a dermatologist or doctor.
- The assistant must not ask for health details.

To add before a real launch: detect obvious health terms in ticket summaries and CRM notes, and redact them. This is tracked as risk R13 in the [risk register](#).

3.5 Security and breaches (Arts. 9 and 20)

- Controllers must use security measures suited to the risk, such as encryption and pseudonymisation, and must test them regularly (Art. 20).
- They must notify the regulator of a breach that affects privacy "at the time it becomes aware" of it, and must tell affected people where needed (Art. 9) [UAE-1].
- The [incident runbook](#) includes a data-leak playbook with a step to notify the regulator.

3.6 Sending data abroad: the model provider (Arts. 22 and 23)

The issue. The assistant sends the chat text to a model through OpenRouter. The servers are probably outside the UAE, so this is a **cross-border transfer**.

The rules.

- Article 22 allows transfers to countries with adequate protection that the regulator has approved.
- Article 23 allows other transfers under conditions such as a binding contract or the person's **explicit consent**, with the details left to the Executive Regulations [UAE-1].

- The Executive Regulations have not been issued, and the regulator is changing (section 1). For now, no list of approved countries can be relied on.

Interim plan (for counsel to confirm).

1. Send the model only what it needs. Mask emails and phone numbers before a model call where possible.
2. Sign data-processing terms with each provider. Pick providers and settings that do not keep or train on the data.
3. Say in the privacy notice that a third-party AI service outside the UAE processes chat messages.

This is tracked as risk R14.

3.7 Rights of the people whose data it is (Arts. 13-17)

People have the right to:

- receive information about their data (Art. 13);
- have it corrected or erased (Art. 15);
- have its processing restricted (Art. 16);
- object to direct marketing (Art. 17) [UAE-1].

The shop policy points people to privacy@example.com (a placeholder) for these requests. The assistant itself should **not** carry out erasure or data export. It opens a ticket for the privacy team.

3.8 Data protection officer (Arts. 10-11)

A DPO is required when processing is high-risk or involves sensitive data on a large scale. A small shop may not meet that threshold, but chat logs that contain health details push in that direction. **For counsel:** decide whether Lumi Skin needs a DPO. In this pack, the **Data protection lead** role owns the privacy risks.

4. If the assistant is deployed inside the DIFC: Regulation 10

Regulation 10 of the DIFC Data Protection Regulations covers personal data processed through "autonomous and semi-autonomous systems", which includes AI systems. It has been in force since 1 September 2023 [DIFC-2]. We could not open the official text. The points below come from two law-firm summaries and must be checked against the Regulation itself [DIFC-2, DIFC-3].

What Regulation 10 asks (as summarised)	How P1 matches it	Gap
Roles. The <i>deployer</i> (the business the system works for) acts as controller. The <i>operator</i> (who runs it) acts as processor.	Lumi Skin is both	None
A clear notice when someone first uses the system. It must cover the processing that is not human-initiated, the human-defined purposes and limits, the outputs, and any codes or certifications the system follows.	P1 shows an AI disclosure at the start of every chat	The notice must also state the purposes and limits, and must link to this governance pack (draft text in section 6)
Human-defined purposes come first.	Purposes are fixed by humans: a short list of allowed tools and a system prompt that sets the task	None known
A register of the system's use cases and processing, supplied on request	The inventory in section 2 and the system card	Turn them into one formal register if Lumi runs in the DIFC
Extra conditions for "high-risk processing" (for example, appointing an Autonomous Systems Officer	Lumi has human approval for every	Ask counsel whether chat processing counts as "high-

example, appointing an Autonomous Systems Officer, or using the system only for human-defined or human-approved purposes)	approval for every money and data change	processing counts as "high-risk processing"
Certification. The Commissioner's certification scheme is "expected in 2026" [DIFC-3]	Not available yet	Watch for the scheme

The July 2025 amendments to the DIFC Data Protection Law added a **private right of action**, so individuals can claim directly [UAE-4]. That raises the cost of getting this wrong inside the DIFC.

5. Checklist before collecting real UAE customer data

- ☐ Counsel confirms the lawful basis for each row of the data inventory.
- ☐ The privacy notice and the AI disclosure appear at the start of every chat in Arabic, English and French. **Sara reviews the Arabic and French wording.**
- ☐ Emails and phone numbers are masked before model calls, or counsel confirms that sending them is acceptable.
- ☐ Data-processing terms are signed with OpenRouter and the model providers, and a "no training on our data" setting is confirmed.
- ☐ Retention periods are set: traces, chat logs and the approval audit log (see the runbook).
- ☐ A process exists for requests to access, correct or erase data, with an owner and a response target.
- ☐ The breach playbook has been rehearsed once (a tabletop exercise).
- ☐ The rules are checked again for news on the Executive Regulations and on the new AI and Data Authority.

6. Draft text: chat privacy notice and AI disclosure (English)

You are chatting with Lumi Skin's **AI assistant**, not a person. It can explain our policies, give general product guidance (not medical advice) and look up your order after you confirm your order ID and email. A member of our team reviews every refund and every address change, and you can ask for a person at any time. We use what you type to answer you and to keep a record of your request. Your messages are processed by an AI service provider that may be outside the UAE. Please do not share card numbers, passwords or health details. Privacy questions: privacy@example.com. How this assistant is governed: [link to this pack].

TODO (Sara): write the Arabic and French versions yourself, and check that they sound natural and polite in each language.

General information only. This is not legal advice. Sources: [sources.md](#).